

Mise en œuvre du Cycle en V

Verisure | Exigence RGD-01 | Dossier de conception et de validation - 24 semaines

1. Cahier des charges : cadrer le besoin

La solution proposée à Verisure est un tableau de bord web permettant à chaque client de consulter l'état de ses appareils connectés. Notre société assurerait sa conception, son développement et son hébergement. Le présent dossier détaille l'exigence RGD-01 et sa validation au cours d'une réalisation prévue sur 24 semaines.

Le risque retenu comme fil conducteur est la consultation du foyer d'un autre client. Une information aussi simple qu'un état d'alarme ou un mouvement peut révéler des habitudes de vie lorsqu'elle est rattachée à un foyer. La réponse ne consiste donc pas seulement à masquer un bouton : le serveur doit contrôler les accès et limiter les données.

Dans le périmètre de la version initiale	Hors périmètre
Accès authentifié au foyer ; essais avec deux foyers fictifs, A et B.	Ouverture à des comptes réels avant autorisations et recette.
État technique d'une caméra, d'une alarme, d'un détecteur de mouvement et d'ouverture.	Images, vidéos, audio et historique de présence.
Tableau de bord en lecture seule ; notice et demandes RGD.	Armement, désarmement, intervention ou télésurveillance.
Connecteur sur une interface autorisée ; qualification, recette et mise en service.	API non autorisée, rétro-ingénierie et certification globale annoncée.
Planification sur 24 semaines ; maintenance et support après livraison.	Volets, lumières et fumée : évolutions ultérieures.

Objectif de la version initiale

Mettre à disposition une vue en lecture seule, avec des accès cloisonnés par foyer, une collecte limitée et un traitement encadré des demandes RGD. Le service complète la consultation des équipements ; il ne remplace ni la protection du logement ni la télésurveillance.

Statut de la proposition

Les choix techniques et le planning sont soumis à validation. Aucun accord fournisseur ni aucune recette ne sont présumés acquis. Les fiches présentent des résultats attendus ; leur statut initial est « non exécuté ».

La démarche suit le Cycle en V : exigences, analyse, conception générale, conception détaillée, réalisation, tests unitaires, d'intégration, de système et recette. Chaque revue confirme les livrables et les conditions de passage à la phase suivante. [1]

2. Une seule exigence, cinq critères observables

RGPD-01 - Protéger les données personnelles du tableau de bord

L'application doit utiliser uniquement les données nécessaires à la consultation des appareils, en réserver l'accès aux personnes autorisées, les protéger pendant leur transmission et leur stockage, maîtriser leur conservation et permettre l'information ainsi que l'exercice des droits.

Les cinq critères ci-dessous déclinent une même exigence. Leur traçabilité relie les choix de conception aux preuves attendues, sans élargir le périmètre fonctionnel de la version initiale. [2, 3, 4]

Critère	Application à la version initiale	Preuves prévues
C1 - Collecter le nécessaire	Uniquement le foyer, l'identifiant et le type d'appareil, son état et la date de mise à jour. Aucun flux vidéo, son, adresse ou historique de présence.	TU-01, TI-01, TS-02
C2 - Réserver l'accès	Chaque requête est contrôlée côté serveur. Le compte A ne peut jamais consulter le foyer B ; le support n'a pas cet accès par défaut.	TI-01, TS-02
C3 - Protéger les échanges et le stockage	HTTPS, base non exposée à Internet, stockage chiffré et secret fournisseur conservé uniquement sur le serveur.	TI-02, TS-01
C4 - Maîtriser la conservation	Dernier état seulement. Après désactivation : collecte et consultation bloquées immédiatement, puis purge des données actives sous 24 h.	TU-02, REC-02
C5 - Informer et organiser les droits	Une notice explique le traitement ; une demande d'accès ou d'effacement est enregistrée et transmise au représentant de Verisure.	REC-01, REC-02

Ce que signifie la validation

L'acceptation repose sur des tests documentés et une revue des mesures organisationnelles. Les huit cas de référence rendent RGPD-01 vérifiable ; ils ne constituent pas, à eux seuls, un audit complet de conformité. La base légale, les contrats, les droits et l'analyse de risque sont des conditions de mise en service. [2, 3]

Un hébergement en France ou dans l'Union européenne est l'orientation proposée, non une preuve autonome de conformité. La sélection en S5-S6 doit aussi examiner les prestataires, leurs accès et les éventuels transferts, puis être validée avant tout traitement réel. [3]

3. Données, responsabilités et conservation

Une fiche de traitement réduite au besoin

Rubrique	Disposition proposée / validation attendue
Finalité	Afficher au client l'état de ses appareils. Pas de publicité, de revente ni d'analyse des habitudes.
Personnes concernées	Titulaire du compte et personnes dont l'activité peut être déduite des états.
Données	Identifiant de compte, lien compte-foyer et dernier état des appareils. Le contenu appareil est limité aux cinq champs de C1.
Destinataires	Client autorisé pour son foyer ; personnels strictement habilités du prestataire pour leur mission. Aucun accès global accordé au support par défaut.
Rôles envisagés	Verisure : responsable de traitement. Notre société : sous-traitant agissant sur ses instructions. Ces rôles dépendent du fonctionnement contractuel retenu. [3]
Base légale envisagée	Exécution du contrat pour la vue demandée par le titulaire, si ce traitement est nécessaire au service. À confirmer par Verisure ; le cas des autres occupants doit être examiné. [2]

Un identifiant comme Foyer-A n'anonymise pas une donnée si une correspondance permet de retrouver son titulaire. Les données du service restent donc à protéger. Les comptes A et B utilisés pour la qualification sont, eux, entièrement fictifs. [8]

Règles de conservation à valider

Un nouvel état remplace le précédent : aucun historique des appareils n'est créé. La désactivation de la vue bloque immédiatement collecte et consultation. La purge supprime les états et le rattachement actif sous 24 h. Un statut minimal de désactivation empêche leur réimportation tant que la liaison fournisseur reste présente ; son retrait doit aussi être défini.

Les journaux ne contiennent ni secret ni contenu des appareils. Les durées des journaux, demandes, marqueurs et sauvegardes sont définies en S7-S8 avec le DPO. La restauration doit réappliquer les désactivations avant la reprise des collectes. Le jeu d'essai est recréable et supprimé à la clôture de la qualification ; aucune donnée client ne sert aux essais.

Les 24 h sont un objectif de service proposé, non un délai universel imposé par le RGPD. Les durées doivent être justifiées par finalité et approuvées avant mise en service. La purge des données actives ne signifie pas une disparition immédiate de toutes les sauvegardes. [9]

Organiser les droits avant la mise en service

La notice expose la finalité, les données, leur origine, la base légale, les destinataires, les durées, les droits et le contact désigné par Verisure. Une demande est enregistrée, vérifiée puis transmise à Verisure ; l'effacement n'est pas automatique dans tous les cas. Le délai normal de réponse est d'un mois, avec prolongation possible dans les conditions du RGPD. [4]

4. Conception générale : une architecture simple

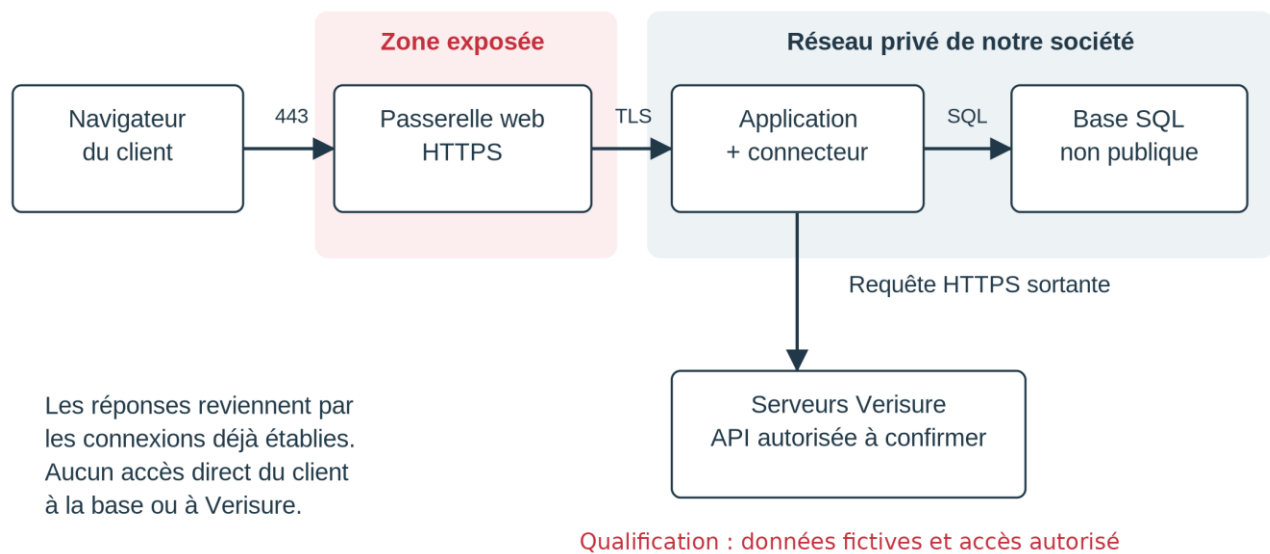


Figure 1. Modèle proposé de circulation des requêtes. Les réponses empruntent les connexions établies. [6, 7]

Nous retenons une application web, un serveur applicatif avec son connecteur, une base SQL privée et une passerelle web. Cette passerelle, aussi appelée reverse proxy, est la porte d'entrée de l'application : elle reçoit les connexions HTTPS puis transmet les requêtes au serveur privé.

Flux	Protection prévue
Navigateur vers passerelle	Entrée HTTPS sur le port 443. Session authentifiée ; aucune clé Verisure dans le navigateur.
Passerelle vers application	Liaison interne chiffrée et filtrée. Contrôle des droits par le serveur sur chaque foyer demandé.
Application vers base	Connexion autorisée depuis l'application seulement. Base sans accès public ; volume chiffré et droits techniques limités.
Connecteur vers Verisure	Appel HTTPS initié depuis notre serveur, vers les seules destinations autorisées. Authentification à convenir avec Verisure.
Administration	Accès distant par VPN avec authentification renforcée ; pas d'interface d'administration publique.

Dépendance fournisseur et qualification

Verisure indique que des données peuvent être partagées avec un tiers autorisé. Les documents publics consultés ne constituent pas une spécification d'API partenaire pour notre application. L'accord, les champs disponibles, les droits, le format et la fréquence des appels sont donc des prérequis, pas des acquis. [5]

En S9-S10, un simulateur HTTPS et deux foyers fictifs servent à construire l'environnement d'essai. L'intégration de S15-S16 doit aussi vérifier le connecteur sur un accès d'essai autorisé par Verisure. Un simulateur seul ne suffit pas à accepter cette liaison. Sans accès convenu, le jalon est bloqué et le planning réexaminé.

5. Conception détaillée et user stories

Le serveur applique trois règles principales : filtrer les données, vérifier le rattachement au foyer et effacer les données d'une vue désactivée. Une application web, un connecteur et une base SQL composent la solution ; aucun découpage en services distribués supplémentaires n'est retenu.

Contrat de l'API applicative proposée

Route proposée	Règle essentielle
GET /api/foyers/{id}/appareils	Session obligatoire. Le serveur vérifie le lien compte-foyer avant la lecture : 200 si autorisé, 403 si refusé, 401 sans session.
GET /api/confidentialite	Retourne la notice de confidentialité, accessible avant et après connexion.
POST /api/demandes-rgpd	Session obligatoire. Enregistre une demande pour le compte connecté, sans accepter l'identité d'un autre compte fournie par le navigateur.

Ces routes sont celles de notre application, non celles du fournisseur. La session identifie le compte et le serveur vérifie sa propre table de rattachement avant chaque lecture. Les comptes A et B sont limités aux essais ; les modalités d'authentification du service doivent être validées avec Verisure en S7-S8.

Quatre besoins utilisateur liés à RGPD-01

User story	Condition d'acceptation
US-01 - En tant que client, je veux consulter les appareils de mon foyer afin de connaître leur état, sans voir les données d'un autre client.	A voit son foyer ; une demande vers B est refusée par le serveur. (C1, C2)
US-02 - En tant que client, je veux comprendre quelles données sont utilisées afin de savoir pourquoi elles sont traitées et pendant combien de temps.	La notice affiche finalité, données, durées, destinataires et contact. (C5)
US-03 - En tant que client, je veux demander l'arrêt de cette vue et l'effacement de ses données afin de garder la maîtrise de leur utilisation.	La demande est suivie ; après validation, l'accès et la collecte cessent puis la purge s'exécute. (C4, C5)
US-04 - En tant que responsable technique, je veux limiter les données reçues et protéger les accès afin de réduire les risques de fuite.	Pas d'image ni de secret dans la réponse navigateur ; la base reste privée. (C1, C3)

Réalisation prévue en S9-S14

S9-S10 préparent les environnements et le simulateur. S11-S14 couvrent le connecteur, les contrôles d'accès, l'affichage, la notice et les demandes RGPD. La purge et la non-réimportation sont ajoutées avant l'intégration. Les tests unitaires accompagnent le code ; les secrets restent hors du dépôt et du navigateur. [6]

Stockage minimal : comptes, rattachements actifs ou désactivés, dernier état par appareil et demandes. Le retour normalisé d'un appareil contient exactement : foyer_id, appareil_id, type, etat, mis_a_jour_le.

6. Planning prévisionnel - 24 semaines

Horizon proposé : environ cinq mois et demi, du lancement à la mise en service. S19-S20 sont réservées aux corrections ; la maintenance se poursuit à partir de S25. Les jalons et les rôles sont détaillés page suivante.

ID	Activité	Pilote	Antécédent	01	02	03	04	05	06	07	08	09	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24
01	Cadrage et lancement	CP	-	X	X																						
02	Accord API et cadre contractuel	CP / CLI	-	X	X	X	X																				
03	Cahier des charges et RGPD-01	CP / DPO	01			X	X																				
04	Architecture, flux et hébergement	RT	02, 03					X	X																		
05	Conception détaillée et règles	RT / DEV	04							X	X																
06	Maquettes et notice de confidentialité	UX / FE	03					X	X	X	X																
07	Préparation des quatre niveaux de tests	QA	03-06*			P	P	P	P	P	P																
08	Environnements et simulateur HTTPS	RT / BE	05, 06									X	X														
09	Connecteur, API et contrôles d'accès	BE	08											X	X	X											
10	Tableau de bord et parcours client	FE	08											X	X	X	X										
11	Demandes RGPD, purge et non-réimportation	BE / RT	08												X	X	X										
12	Tests unitaires au fil du code	DEV	09-11*											E	E	E	E										
13	Tests d'intégration	BE / QA	09-12															E	E								
14	Tests système et sécurité	QA / RT	13																	E	E						
15	Corrections et non-régression	DEV / QA	14																		E	E					
16	Recette client et revue du dossier RGPD	CLI / QA	15																				E	E			
17	Mise en service et transfert au support	RT / CP	16																						X	X	
18	Pilotage et revues RGPD / sécurité	CP / DPO	Transversal	P	P	P	P	P	P	P	P	P	P	P	P	P	P	P	P	P	P	P	P	P	P	P	P

S = semaine depuis le lancement ; les barres indiquent des fenêtres de travail, pas une affectation à plein temps. X : réalisation ; P : préparation / pilotage ; E : vérification. Un astérisque signale une activité conduite en parallèle des tâches indiquées. Sans astérisque, les antécédents doivent être terminés.

CP : chef de projet ; CLI : client ; RT : référent technique ; BE / FE : back-end / front-end ; DEV : développement ; QA : tests ; UX : conception de l'interface ; DPO : délégué à la protection des données.

6.1 Jalons, responsabilités et dépendances

Jalon	Décision attendue	Responsable de validation
V1 - fin S4	Périmètre et RGPD-01 approuvés ; faisabilité de l'accès fournisseur et cadre contractuel confirmés.	Client + CP, avec DPO.
V2 - fin S8	Architecture, règles, maquettes et cas de test validés avant réalisation.	RT + QA ; avis DPO.
V3 - fin S14	Version assemblable ; tests unitaires passants et jeux d'essai prêts.	RT + développement.
V4 - fin S20	Intégration et système validés ; aucune anomalie bloquante avant recette.	QA + RT.
V5 - fin S22	Recette acceptée et conditions RGPD / sécurité levées ; autorisation de mise en service.	Client, sur avis RT / DPO.
V6 - fin S24	Mise en service stabilisée ; documentation et responsabilités transmises au support.	CP + exploitation + client.

Équipe et instances de suivi

La maîtrise d'ouvrage (MOA), représentée par Verisure, exprime le besoin et prononce la recette. Notre société assure la maîtrise d'œuvre (MOE). L'équipe cible réunit un chef de projet, un référent technique, un développeur front-end, un back-end et un testeur QA, avec des interventions UX, DPO et sécurité adaptées aux phases. [1]

Un point hebdomadaire suit les travaux et les anomalies ; un comité mensuel examine délais, risques et décisions. Le DPO et le référent sécurité interviennent dès le cadrage puis aux revues. Les disponibilités et la charge partagée du back-end sont confirmées avant engagement.

Maîtriser les changements et les marges

Un ajout, tel que la vidéo, fait l'objet d'une demande formalisée : données supplémentaires, risques, charge et tests. Sans accord du client, il reste hors périmètre. S19-S20 constituent une réserve de corrections et de non-régression, non une capacité d'ajout fonctionnel.

La chaîne de dépendances passe par l'accès fournisseur, la conception validée, la version assemblable, l'intégration, le système et la recette. Un retard sur un jalon bloquant conduit à replanifier ; le simulateur ne remplace pas la validation de la liaison fournisseur.

7. Préparer les tests avant de les exécuter

La recette et les tests système sont préparés avec le besoin ; l'intégration avec l'architecture ; les tests unitaires avec la conception détaillée. Les fiches sont consolidées en fin S8. L'exécution remonte ensuite le V, des composants jusqu'à la recette. [1]

Cas	Niveau	Critères	Préparation	Exécution prévue
TU-01	Unitaire	C1	S7-S8	S11-S14
TU-02	Unitaire	C4	S7-S8	S12-S14
TI-01	Intégration	C1, C2	S5-S6	S15-S16
TI-02	Intégration	C3	S5-S6	S15-S16
TS-01	Système	C3	S3-S4	S17-S18
TS-02	Système / E2E	C1, C2	S3-S4	S17-S18
REC-01	Acceptation / recette	C5	S3-S4	S21-S22
REC-02	Acceptation / recette	C4, C5	S3-S4	S21-S22

Ne pas confondre les niveaux

Un test unitaire vérifie une fonction isolée, comme le filtrage. Un test d'intégration vérifie plusieurs composants assemblés, par exemple l'API et la base. Un test système évalue l'ensemble. Le test de bout en bout (E2E) est ici un parcours système depuis le navigateur jusqu'aux données ; il n'est pas synonyme de test d'intégration. La recette correspond à la décision du client sur les attentes prévues.

Traçabilité de RGPD-01

Critère	Tests qui apportent une preuve
C1 - Collecter le nécessaire	TU-01, TI-01, TS-02
C2 - Réserver l'accès	TI-01, TS-02
C3 - Protéger les échanges et le stockage	TI-02, TS-01
C4 - Maîtriser la conservation	TU-02, REC-02
C5 - Informer et organiser les droits	REC-01, REC-02

Règles du carnet de recette

Chaque fiche précise préconditions, actions, résultat attendu et preuve à conserver. Après exécution, le testeur renseigne la date, la version, le résultat observé et, si besoin, le numéro d'anomalie. Les statuts possibles sont : non exécuté, réussi, échoué ou bloqué.

Les huit tests de référence sont obligatoires pour valider RGPD-01, avec les contrôles complémentaires décidés lors des revues. Une fuite entre foyers, une fuite de secret ou un effacement défaillant bloque la recette. Après correction, les tests affectés et le parcours principal sont rejoués en S19-S20 ; les corrections restent possibles dès les premiers essais.

8. Carnet de tests - unitaires et intégration

Jeu d'essai exclusivement fictif. Les résultats ci-dessous sont attendus, non constatés.

TU-01 - Filtrer les données reçues

Unitaire | C1 | S11-S14 | Développement

Préconditions. Un objet fictif contient les cinq champs autorisés et des champs supplémentaires : adresse, image et secret.

Actions. Appeler la fonction de filtrage avec cet objet. Comparer exactement les clés de sortie à la liste autorisée.

Attendu. Les cinq champs prévus sont présents. Adresse, image et secret sont absents, sans journalisation du contenu brut.

Preuve : Rapport du test et comparaison des clés.

Statut : non exécuté | Date / version : _____ | Observé / anomalie : _____

TU-02 - Purger un foyer désactivé

Unitaire | C4 | S12-S14 | Développement

Préconditions. Un jeu en mémoire contient un foyer A actif et un foyer B désactivé, avec des états fictifs. L'heure est contrôlée.

Actions. Appeler la purge avec une exécution simulée de la tâche quotidienne, au plus tard 24 h après la désactivation.

Attendu. Les états de B sont supprimés. Ceux de A sont inchangés. La fonction ne supprime pas un foyer actif.

Preuve : Jeu de données avant/après et rapport du test.

Statut : non exécuté | Date / version : _____ | Observé / anomalie : _____

TI-01 - Vérifier les droits avec la base

Intégration | C1, C2 | S15-S16 | Développement + QA

Préconditions. API et base d'essai assemblées. Le compte A est lié uniquement au foyer A ; B possède ses propres appareils.

Actions. Avec la session A, appeler GET /api/foyers/A/appareils puis la même route pour B. Répéter sans session.

Attendu. A : HTTP 200 et données filtrées de A seulement. B : HTTP 403 sans données du foyer. Sans session : HTTP 401.

Preuve : Réponses HTTP issues du jeu fictif.

Statut : non exécuté | Date / version : _____ | Observé / anomalie : _____

TI-02 - Refuser un accès fournisseur invalide

Intégration | C3 | S15-S16 | Développement + QA

Préconditions. Le connecteur dialogue avec le simulateur HTTPS. Un secret d'essai invalide provoque une réponse HTTP 401.

Actions. Déclencher une collecte puis lire le résultat et les journaux. Vérifier qu'aucun contournement d'authentification n'est tenté.

Attendu. Aucune nouvelle donnée enregistrée ; source signalée indisponible. Aucun secret ni contenu brut dans l'erreur ou les journaux.

Preuve : Réponse du simulateur et journal technique limité.

Statut : non exécuté | Date / version : _____ | Observé / anomalie : _____

8. Carnet de tests - système et acceptation

Jeu d'essai exclusivement fictif. Les résultats ci-dessous sont attendus, non constatés.

TS-01 - Vérifier les protections de l'environnement

Système | C3 | S17-S18 | QA + référent technique

Préconditions. Environnement isolé avec zone externe d'essai, passerelle HTTPS et réseau privé. Configuration accessible au testeur.

Actions. Depuis la zone externe, tester la passerelle puis l'accès direct à la base et à l'administration. Inspecter TLS, le chiffrement du volume et les échanges du navigateur.

Attendu. Seule la passerelle applicative prévue est accessible ; base et administration sont bloquées. Certificats vérifiés, volume chiffré, secret fournisseur absent du navigateur.

Preuve : Contrôles réseau et relevé de configuration. Un environnement absent rend ce test bloqué, pas réussi.

Statut : non exécuté | Date / version : _____ | Observé / anomalie : _____

TS-02 - Parcourir le tableau de bord de bout en bout

Système / E2E | C1, C2 | S17-S18 | QA

Préconditions. Navigateur, interface, API, base et simulateur sont reliés. Les comptes A et B sont préparés.

Actions. Se connecter avec A, ouvrir le tableau de bord, puis modifier la requête pour viser B. Se déconnecter et réessayer.

Attendu. Seuls les états de A apparaissent, sans image ni historique. B est refusé côté serveur. Après déconnexion, aucune consultation n'est possible.

Preuve : Captures du parcours et réponses HTTP associées.

Statut : non exécuté | Date / version : _____ | Observé / anomalie : _____

REC-01 - Valider l'information et les responsabilités

Acceptation / recette | C5 | S21-S22 | Représentant client + CP

Préconditions. Notice de confidentialité, fiche de traitement et dossier des conditions de mise en service disponibles.

Actions. Lire la notice depuis l'interface. Vérifier les données, finalités, durées, destinataires, base envisagée, droits et point de contact ; relire la répartition des rôles.

Attendu. Notice et traitement concordent. Responsabilités, base légale, contrat et durées disposent des validations requises. Un prérequis non levé bloque l'ouverture ; la relecture ne vaut pas certification globale.

Preuve : Grille de relecture, validations référencées et décision de recette.

Statut : non exécuté | Date / version : _____ | Observé / anomalie : _____

REC-02 - Suivre une demande puis vérifier l'effacement

Acceptation / recette | C4, C5 | S21-S22 | Représentant client + QA

Préconditions. A et B disposent de données fictives. La demande de A est approuvée par le représentant client dans le scénario de test.

Actions. Enregistrer la demande, simuler sa transmission et son instruction. Désactiver A, lancer la purge quotidienne, puis déclencher une nouvelle collecte.

Attendu. Demande suivie ; A n'est plus consultable ni collecté. Ses états sont effacés sous 24 h et ne réapparaissent pas. B reste intact. L'effacement ne concerne que notre copie, pas les données conservées par Verisure.

Preuve : Suivi de demande, contrôle de la base et journal de collecte.

Statut : non exécuté | Date / version : _____ | Observé / anomalie : _____

9. Livraison, maintenance et support

Livraison et mise en service en S23-S24

La livraison prévue comprend l'application validée, sa configuration, les spécifications, les schémas, les rapports de tests et le dossier d'exploitation. Le procès-verbal identifie version, périmètre, anomalies résiduelles et décision du client. La recette de S21-S22 conditionne l'ouverture du service ; elle n'est jamais présumée acquise.

La remise s'effectue par un espace documentaire et un dépôt de code à accès restreint. Les secrets sont transmis par le canal sécurisé convenu ; aucun identifiant fournisseur ni aucune donnée client ne figure dans les supports de présentation.

Conditions d'ouverture du service

Avant ouverture : faire confirmer l'accès technique, les finalités et la base légale ; formaliser les instructions et le contrat ; valider notice, durées, habilitations et hébergement. L'analyse de risque est engagée au cadrage ; une AIPD est menée avant traitement si le risque élevé l'impose. Sauvegardes, restauration et réapplication des effacements doivent également être vérifiées. [2, 3]

Support initial puis maintenance récurrente

Moment	Action et responsable
S23-S24 : mise en service	Le référent technique surveille l'ouverture, vérifie les accès et transmet la procédure de retour arrière au support.
À partir de S25	L'exploitation surveille les erreurs, applique les mises à jour et revoit les habilitations selon le contrat de support.
Après une modification	Le développement corrige ; la QA rejoue les tests affectés avant livraison, y compris si l'API fournisseur change.
Demande d'un client	Le support enregistre et transmet au contact Verisure ; aucun droit général de lecture des foyers ne lui est accordé.

Trois risques à suivre

Accès fournisseur retardé : alerter au jalon concerné et replanifier. Dérive vers la vidéo : soumettre une demande de changement distincte. Fuite entre foyers : bloquer la recette, corriger le contrôle serveur et rejouer TI-01 puis TS-02.

Traitement d'un incident de sécurité

Isoler l'accès en cause, révoquer le secret compromis et préserver les preuves utiles sans les diffuser. Notre société, sous-traitante, alerte Verisure dans les meilleurs délais. Le responsable de traitement évalue le risque et notifie l'autorité compétente, si nécessaire, dans les meilleurs délais et si possible sous 72 h après en avoir pris connaissance. L'information des personnes est examinée en cas de risque élevé. [3]

10. Repères et références

Terme	Explication utile
API	Point de dialogue entre deux logiciels ; une API n'est pas nécessairement publique.
HTTPS / TLS	Protection de la communication pendant son transport ; elle ne décide pas qui a le droit de lire un foyer.
Passerelle / reverse proxy	Porte d'entrée web qui relaie les requêtes vers notre application privée.
VPN	Accès distant protégé, utilisé ici pour l'administration, pas pour tous les clients.
RGPD / ISO 27001	Le RGPD est un règlement. ISO/IEC 27001 est une norme de management de la sécurité, pas un protocole domotique. Aucune certification n'est revendiquée. [10]

La validation relie chaque protection à une règle, à un responsable et à une preuve. Un serveur privé, le chiffrement ou une norme ne remplacent ni les contrôles d'accès ni les décisions relatives aux données.

Références

[1] La Plateforme - KickOff : Cycle en V. Phases, rôles, livrables et risques ; pages 7-19 et 23-29.

[2] CNIL - RGPD, chapitre II, articles 5 et 6 : principes et bases légales.

[3] CNIL - RGPD, chapitre IV, articles 25, 28, 30, 32 à 35 : conception, sous-traitance, sécurité, incidents et AIPD.

[4] CNIL - RGPD, chapitre III, articles 12 à 17 : information, accès et effacement.

[5] Verisure France - Informations sur les données des produits connectés et services associés (Data Act).

[6] CNIL - Sécurité : API - Interfaces de programmation applicative.

[7] CNIL - Sécurité : Protéger le réseau informatique.

[8] CNIL - Minimiser les données collectées.

[9] CNIL - Les durées de conservation des données.

[10] ISO - ISO/IEC 27001 : systèmes de management de la sécurité de l'information.

Références CNIL et Verisure vérifiées le 13 septembre 2026. Planning et architecture proposés : validation requise avant engagement.